

operations can be gradual (where management makes incremental changes over time) or all at once. Regardless, continuous improvement relies on management and personnel; therefore, management should have a process in place to recommend changes.

To improve the management and governance of operations, management should develop improvement strategies for operations and prioritize projects. Management should make decisions related to improvement based on the potential benefit and ease of implementation, with a focus on important IT processes and core competencies.

Management should have a process to measure the results of continuous improvement efforts. This can be accomplished by establishing a scorecard with KPIs to measure current performance and monitor the results of new improvements. Validating these measurements could include the following:

- Implementation of organizational structures that support improvement.
- Designation of risk management responsibilities.
- Facilitation for sharing vital business information.
- Communication of strategies and goals.

There are several types of continuous improvement, including for processes and services.

- **Process improvement:** Process improvement includes the actions taken to improve the quality of the organization's processes aligned with the business needs and the needs of other concerned parties. It should be an ongoing practice as part of the entity's continuous improvement efforts. Results can include improved quality, strengthened security, increased productivity and efficiency, and improved employee skills.
- **Service improvement:** Service improvement includes the actions taken to identify and execute methods to improve an entity's services and align them with its business objectives. It should be implemented enterprise-wide and augment the entity's ability to provide value to its stakeholders and customers. Management can facilitate the entity's continuous improvement efforts through the following:
 - Maturity assessments.
 - Gap analyses.
 - Benchmarking.
 - Improvement planning.

VII EVOLVING TECHNOLOGIES

Entities use a variety of evolving technologies (e.g., cloud, zero trust architecture [ZTA], AI and ML, and IoT) that may impact architecture, infrastructure, and operations functions. This section provides general information relating to these evolving technologies and, when appropriate, certain risks and control principles discussed in prior sections of this booklet.

VII.A Cloud Computing

Cloud computing environments are enabled by virtualization technologies, which allow cloud service providers to segregate and isolate multiple clients on a common set of physical or virtual hardware. NIST defines cloud computing as “a model for enabling ubiquitous, convenient, on-demand network access to a shared pool of configurable computing resources (e.g., networks, servers, storage, applications, and services) that can be rapidly provisioned and released with minimal management effort or third-party service provider interaction.”⁸⁶ Cloud systems provide several benefits, including scalability of resources and consistency in deployment of controls across systems and software.

For the purposes of this section of the booklet, when the term “cloud service provider” is used, it refers to the provider offering cloud computing services. When the term “entity” is used, it refers to the client receiving cloud computing services.

As defined by NIST, “cloud computing has five essential characteristics, three service models, and four deployment models.”⁸⁷

VII.A.1 Essential Characteristics

According to the NIST definition, cloud implementations take advantage of all of the following five “essential characteristics.”⁸⁸ Some entities may characterize their environment as “cloud computing” without it exhibiting all five characteristics. NIST describes the five essential characteristics as follows:

- **On-demand self-service:** A consumer can unilaterally provision computing capabilities, such as server time and network storage, as needed automatically without requiring human interaction with each third-party service provider.
- **Broad network access:** Capabilities are available over the network and accessed through standard mechanisms that promote use by heterogeneous thin or thick client platforms (e.g., mobile phones, tablets, laptops, and workstations).

⁸⁶ Refer to [NIST SP 800-145, *The NIST Definition of Cloud Computing: Recommendations of the National Institute of Standards and Technology*](#).

⁸⁷ [Ibid.](#)

⁸⁸ [Ibid.](#)

- **Resource pooling:** The cloud service provider's computing resources are pooled to serve multiple consumers using a multi-tenant model, with different physical and virtual resources dynamically assigned and reassigned according to consumer demand. The customer generally has no control or knowledge over the exact location of the provided resources but may be able to specify location (e.g., country, state, or data center). Examples of resources include storage, processing, memory, and network bandwidth.
- **Rapid elasticity:** Capabilities can be elastically provisioned and released, in some cases automatically, to scale rapidly outward and inward commensurate with demand. To the consumer, the capabilities available for provisioning often appear to be unlimited and can be appropriated in any quantity at any time.
- **Measured service:** Cloud systems automatically control and optimize resource use by leveraging a metering capability (e.g., storage, processing, bandwidth, and active user accounts) appropriate to the type of service. Resource usage can be monitored, controlled, and reported, providing transparency for the provider and consumer of the utilized service.

VII.A.2 Cloud Service Models

There are generally three key cloud service models⁸⁹ used in cloud computing implementations.⁹⁰ The optimal architecture for a given application or service is determined by consideration of the entity's requirements, including data classification, data residency, service or application availability, and interfaces with external services and data stores.

NIST describes the service models⁹¹ as follows:

- **Software as a service (SaaS):** SaaS allows entities to use applications running on a cloud infrastructure. The entity does not control or manage the applications or the environment in which the applications are running, including the network, servers, OSs, storage, or individual application capabilities. In this model, the end user and the entity generally have limited ability to customize the user interface of the cloud service, with the exception of some user-specific application configuration settings.
- **Platform as a service (PaaS):** PaaS provides entities with the ability to deploy applications created or acquired by the entity using programming languages, libraries, services, and tools supported by the cloud service provider. The entity does not manage or control the cloud infrastructure (e.g., network, servers, OSs, or storage); it does control the deployed applications and possibly the configuration settings.
- **Infrastructure as a service (IaaS):** IaaS provides entities with the ability to provision processing, storage, networks, and other fundamental computing resources where the entity is able to deploy and run software, which can include OSs and applications. The entity does not manage or control the underlying cloud infrastructure; it does control OSs, storage, and

⁸⁹ Refer to [NIST SP 500-316, Framework for Cloud Usability](#).

⁹⁰ There are a variety of other cloud service models (e.g., disaster recovery as a service, backup as a service, and desktop as a service). The focus for the purposes of this booklet are the key cloud service models used here as a baseline for most others.

⁹¹ Refer to [NIST SP 500-316, Framework for Cloud Usability](#).

deployed applications. Entities have the maximum flexibility to customize their cloud services and user interfaces.

Management may choose to leverage the cloud in different ways. Some entities outsource certain applications or processes, such as storage or data backup to the cloud (as part of SaaS). Others may choose to develop their own applications; these entities, however, rely on the cloud service provider to provide and maintain the OS (as part of PaaS). Still others may choose to outsource only the physical hardware to cloud service providers, while maintaining the OS and applications themselves (as part of IaaS).

VII.A.3 Cloud Deployment Models

As with cloud service models, management can deploy cloud services in different ways. NIST describes the deployment models as follows:⁹²

- **Private cloud:** The private cloud infrastructure is provisioned for exclusive use by a single entity with multiple business units. The private cloud infrastructure may be owned, managed, and operated by the entity, a third party, or some combination of the two, and it may exist on or off premises.
- **Community cloud:** The community cloud infrastructure is provisioned for exclusive use by a specific community (e.g., government agencies, financial services, or banks) of entities that have shared concerns (e.g., mission, security requirements, policy, and compliance considerations). The community cloud infrastructure may be owned, managed, and operated by one or more of the constituents in the community, a third party, or some combination of the two, and it may exist on or off premises.
- **Public cloud:** The public cloud infrastructure is provisioned for open use by the general public. The public cloud infrastructure may be owned, managed, and operated by a business or an academic or government organization, or some combination of the two. It exists on the premises of the cloud service provider.
- **Hybrid cloud:** The hybrid cloud infrastructure is a composition of two or more distinct cloud infrastructures (e.g., private, community, or public) that are unique entities but are bound together by standardized or proprietary technology that enables data and application portability (e.g., cloud bursting for load balancing between clouds).

Entities may use more than one cloud service provider for different operations or to augment continuity and resilience for operations in the cloud. The use of multiple cloud service providers may reduce single-provider reliance. Entities may rely on cloud bursting⁹³ capabilities for situations requiring increased capacity or for business continuity purposes. Entities may use a cloud broker to act as an informed intermediary between management and the cloud service provider. The use of a cloud broker may also supplement the capabilities of entity management and staff.

⁹² Refer to [NIST SP 800-145, *The NIST Definition of Cloud Computing: Recommendations of the National Institute of Standards and Technology*](#).

⁹³ The goal of cloud bursting is to maintain required service levels for an entity's data-center hosted process, by dynamically allocating or deallocating cloud computer or storage resources to service current demands.

VII.A.4 Shared Responsibilities

In cloud computing environments, entities may outsource the management of different controls over information and technology assets and operations to the cloud service provider. Careful review of the contract between the entity and the cloud service provider along with an understanding of the division of shared responsibilities and related risks are important for implementing appropriate controls. The contract defines the service-level expectations and control responsibilities for both the entity and the cloud service provider. To maintain security consistent with an entity's internal standards, there may be a need for controls in addition to those a cloud service provider contractually offers.

Depending on the service and deployment model used, management should understand the shared responsibilities associated with cloud computing. As presented by NIST, “compared to traditional IT systems, where one organization has control over the whole stack of computing resources⁹⁴ and the entire life cycle of the systems, cloud service providers and cloud consumers collaboratively design, build, deploy, and operate cloud-based systems. The split of control means both parties now share the responsibilities in providing adequate protections to the cloud-based systems.” It is important to understand what controls are implemented by the cloud service provider for the cloud service provider's own operations and what security controls are implemented and operated to ensure the security of the entity's content and applications.

For each service model, there are typically different shared responsibilities between the entity and the cloud service provider for implementing and managing controls. The following includes some of the controls that are the responsibility of either the entity or the cloud service provider, or both in some cases, depending on the service model and contract provisions.

- Managing the underlying cloud infrastructure systems (e.g., network, servers, or storage) or software.
- Managing and implementing controls over the hypervisor(s).
- Provisioning and configuring cloud platform resources.
- Implementing user-specific application configuration settings and user access and identity management.
- Managing entity data (e.g., classifying assets and employing encryption).
- Developing and deploying software residing on the cloud service provider's platforms.
- Managing the physical data center, including environmental controls (e.g., heating, cooling, and fire and flood protection), power, physical security, and data communications connections.
- Implementing controls over data access, theft of user credentials, regulatory compliance, and data leakage.

⁹⁴ [NIST SP 500-292, NIST Cloud Computing Reference Architecture: Recommendations of the National Institute of Standards and Technology](#), states, “In cloud computing, a stack of computing resources refers to the group of services that the institution purchases from a cloud computing service provider.”

Figure 5. Example of Shared Responsibilities in a Cloud Computing Environment

	On Premise Responsibility	IaaS Responsibility	PaaS Responsibility	SaaS (and Traditional Outsourcing) Responsibility
Risk Management (Mgmt) / Administrative Controls	Risk Mgmt Strategy	Risk Mgmt Strategy	Risk Mgmt Strategy	Risk Mgmt Strategy
	Policy	Policy	Policy	Policy
	Organization	Organization	Organization	Organization
	App. Administration	App. Administration	App. Administration	App. Administration
	IAM/Access Controls	IAM/Access Controls	IAM/Access Controls	IAM/Access Controls
Technical Controls	Applications	Applications	Applications	Applications
	Data	Data	Data	Data
	Runtime	Runtime	Runtime	Runtime
	Middleware	Middleware	Middleware	Middleware
	OS	OS	OS	OS
	Virtualization	Virtualization	Virtualization	Virtualization
	Servers	Servers	Servers	Servers
	Storage	Storage	Storage	Storage
Physical Controls	Networking	Networking	Networking	Networking
	Facility	Facility	Facility	Facility

Note: Based on a diagram from the Cloud Security Alliance, FFIEC members augmented the diagram by adding the layer of risk management and administrative controls. This chart is an example of how the responsibilities may be divided between the entity and the cloud service provider as defined in the contract. Dark blue boxes represent the entity's responsibility. White boxes represent the cloud service provider's responsibility. Boxes shaded in light blue are examples of responsibilities that may be assigned to either or both the entity and the cloud service provider.

Regardless of the environment or service model used, the entity retains overall responsibility for the safety and soundness of cloud services and the protection of sensitive customer and entity information.⁹⁵ Refer to the *IT Handbook's* “[Outsourcing Technology Services](#)” and “[Information Security](#)” booklets for more information on third-party service provider oversight.

VII.A.5 Risk Considerations for Cloud Computing

Cloud computing is exposed to the same threats, vulnerabilities, and risks as other technology environments, whether the cloud computing environment is managed internally at the entity or at a third-party service provider. Cloud computing may involve different security control configurations and processes than those employed in more traditional network architectures. Simply moving existing network technology to the cloud may not be appropriate. Controls, policies, and procedures may not translate effectively to a cloud-based environment. There are tools (e.g., cloud access security broker) designed specifically to assist with the implementation of security controls in a cloud environment.

⁹⁵ Refer to the Information Security Standards: 12 CFR 30, appendix B (OCC); 12 CFR 208, appendix D-2, and 12 CFR 225, appendix F (FRB); 12 CFR 364, appendix B (FDIC); and 12 CFR 748, appendix A (NCUA).

Another risk consideration is the aspect of tenancy. Applications or services can exist in single or multi-tenant environments. Control requirements may vary by tenant, with some requiring a higher level of security than others. Misuse or abuse by one tenant could potentially weaken the security posture of other tenants. Inadvertent or deliberate failure of a security control could adversely affect other tenants in the same environment. For example, a DOS attack on the cloud service provider, or even a single tenant, could affect the other tenants.

Third-party assurance reviews (e.g., SOC reviews, penetration tests, and vulnerability assessments) can provide an understanding of the cloud service provider's control environment and its ability to meet an entity's control expectations (e.g., compliance with applicable laws and regulations). Refer to the FFIEC's joint statement⁹⁶ for more information.

VII.A.5(a) *Access Control Considerations*

"Access control dictates how subjects (i.e., users and processes) can access objects based on defined access control policies to protect sensitive data and critical computing objects in the cloud systems."⁹⁷ While cloud computing offers significant flexibility, security considerations can be complicated by the various service and delivery models and shared responsibilities. In general, access control considerations for IaaS are also applicable to PaaS and SaaS, and access control considerations for PaaS are also applicable to SaaS, although variations do exist.

Challenges of access control system design are tied to the essential characteristics of cloud computing mentioned previously, plus risk from data sharing. These challenges and risk considerations include those applied to the following elements in cloud environments:

- Network
- Hypervisor
- VMs
- APIs
- Multi-tenancy
- Attribute and role management
- Data replication and destruction

When addressing these elements, additional considerations of access control in a cloud environment include:

- Cloud virtualization adds access control and security management concerns, as risk may be compounded by the volume of VMs created and changed in the cloud.
- Access control lists for networks and network boundaries, hypervisors, VMs, and APIs to define and implement appropriate levels of access on different users.
- Access control security and privacy offered by the PaaS provider to protect the applications and data from potential leaks, such as data in OS memory caches.

⁹⁶ FFIEC, [Security in a Cloud Computing Environment](#).

⁹⁷ Refer to [NIST SP 800-210, General Access Control Guidance for Cloud Systems](#).

- In SaaS, the provider should not have unnecessary or inappropriate access to SaaS systems or customer data residing on or accessible by them.
- The design of access control should include multi-tenancy situations to ensure appropriate segregation of entity data from other clients' applications.

For more information on access control and security in cloud environments, refer to NIST.⁹⁸ Refer to the *IT Handbook's* "[Information Security](#)" and "[Outsourcing Technology Services](#)" booklets for additional information.

VII.B Zero Trust Architecture

According to NIST, ZTA is "an enterprise cybersecurity architecture that is based on zero trust principles and designed to prevent data breaches and limit internal lateral movement."⁹⁹ As an entity's complexity increases, the entity may operate several internal networks, remote offices with their own local infrastructure, remote or mobile personnel, and cloud services.¹⁰⁰ Legacy methods of perimeter-based network security may no longer be appropriate in a more complex IT environment. If an entity's perimeter-based and internal network security is not fully effective, a breach of the perimeter can allow unhindered lateral movement inside the network. These concerns have led to the development of a model for cybersecurity known as zero trust.¹⁰¹

ZTA assumes all networks are untrusted, including internal networks. Within ZTA, implicit trust is not granted to systems and users based on their physical or network location (e.g., LANs or the internet). Access to data resources is granted only when the resource is required and authentication (for both users and devices) is performed before the connection is established. ZTA focuses on protecting resources, rather than network segments using authentication and authorization, while minimizing reliance on implicit trust zones. Additionally, it focuses on reducing delays caused by authentication methods that are not located within an entity-owned network boundary.¹⁰²

Designing for zero trust enables entities to securely accommodate the complexity of a diverse set of business cases by informing virtually all access decisions and interactions between systems.¹⁰³ Management may consider adoption of zero trust principles in architecture decisions. ZTA principles include the following:¹⁰⁴

⁹⁸ [Ibid.](#)

⁹⁹ [NIST SP 800-207, Zero Trust Architecture.](#)

¹⁰⁰ [Ibid.](#)

¹⁰¹ [Ibid.](#)

¹⁰² [Ibid.](#)

¹⁰³ [Ibid.](#)

¹⁰⁴ Principles are derived from [NIST SP 800-207, Zero Trust Architecture.](#)

- All data sources and computing services are considered resources.
- All communication is secured regardless of network location.
- Access to individual entity resources is granted on a per-session basis and in a secure manner regardless of network location, user, or device.
- Authentication and authorization for access to resources are determined by user and device analytics and behavioral attributes (e.g., network location, device characteristics, and access time or day) compared to deviations from baselined patterns.
- Rigorous access controls (e.g., using least privilege and granular trust zones around an entity's digital resources) are enforced. These controls include data-level protections, robust identity architecture, and strategic micro-segmentation.
- Owned and associated devices are monitored to ensure that they remain in the most secure state possible. The entity continually inspects, monitors, and logs network traffic and uses the information to improve its security posture.
- Evaluation of access requests and network traffic behaviors occurs in real time over the length of open connections while continually and consistently reassessing access to the entity's resources.

VII.C Microservices

Microservices are a set of containers that work together to compose an application. Essentially, each microservice is an independent building block used for building an application, including the communications and authentication. Each microservice is a mini application loosely coupled¹⁰⁵ to serve a singular function (e.g., database access or messaging) that can be integrated to collectively build an application. During the communication events of any pair of interactions (e.g., client-to-microservice, microservice-to-microservice, or microservice-to-egress service), each party has distinct identities and performs mutual authentication.

Each microservice typically implements one (rarely more) distinct business process or functionality (e.g., storing customer details or displaying a product catalog). NIST 800-204A¹⁰⁶ states that a microservice has two broad functions:

- Business logic, which implements the business functionalities, computations, and service composition or integration logic.
- Network functions, which manage the inter-service communication mechanisms and are built on top of the underlying OS level network stack.

Microservices software is used in architecture designs where complex applications are composed of small, independent services that exchange data and procedural requests. Microservices-based application architectures provide inherent scalability, agility of deployment, and availability of

¹⁰⁵ NIST SP 800-204, [Security Strategies for Microservices-based Application Systems](#), states, "For large applications, splitting the application into loosely coupled components enables independence between the developer teams assigned to each component. Each team can then optimize by choosing its own development platform, tools, language, middleware, and hardware based on their appropriateness for the component being developed."

¹⁰⁶ Refer to [NIST SP 800-204A, Building Secure Microservices-based Applications Using Service-Mesh Architecture](#).

tools to facilitate error-free configuration and deployment. Although a microservices-based application can be implemented purely as an enterprise application, it is generally identified as a cloud-native application that includes service-based architecture, API-driven communications, and container-based infrastructure.¹⁰⁷

The implementation of microservices infrastructure differs from legacy distributed systems as there are multiple services configured to operate at designated locations (IP address and port number). When using microservices-based applications, the following are key elements¹⁰⁸ to consider in the entity's infrastructure:

- There are a substantial number of services and many instances associated with each service with dynamically changing locations.
- The number of instances associated with a service can vary based on the load fluctuations using features such as autoscaling.
- A feature to discover a service while making a service request. A common approach to implementing this feature is the use of a service registry.¹⁰⁹
- Each of the microservices may be implemented in VMs or as containers, which may be assigned dynamic IP addresses, especially when they are hosted in an IaaS or SaaS cloud service.
- Load balancing is needed for multiple instances of the same service where the loads on these instances should be evenly distributed to avoid delayed responses or service crashes due to overload.¹¹⁰
- Microservices take advantage of a variety of features,¹¹¹ including:
 - Circuit breakers.¹¹²
 - Rate limiting, or throttling.
 - Version control.
 - Canary releases.¹¹³

The increasing adoption of microservices-based applications in cloud and large enterprise environments has prompted the identification of an infrastructure that provides a comprehensive,

¹⁰⁷ Refer to NIST SP 800-204, [Security Strategies for Microservices-based Application Systems](#).

¹⁰⁸ NIST discusses several key elements for consideration in [NIST SP 800-204A, Building Secure Microservices-based Applications Using Service-Mesh Architecture](#).

¹⁰⁹ A service registry consists of a directory where new service instances created for the microservices-based application register themselves while service instances going offline are deleted from it.

¹¹⁰ Refer to [NIST SP 800-204A, Building Secure Microservices-based Applications Using Service-Mesh Architecture](#).

¹¹¹ [Ibid.](#)

¹¹² Using circuit breakers involves setting a threshold for the failed responses from an instance of a microservice and cutting off forwarding requests to that instance when the failure is above the threshold (e.g., when the circuit breaker trips).

¹¹³ Canary releases serve as an early warning system for potential problems with the microservices.